

Audit-Tail Final Report

Project: **vulnerable-invoice-service** · Stage 5 (aggregate) · Generated 2026-07-13 · Health Score: **85 / 100**

Grade B — minor issues (unmerged)

Executive summary

- **23** dependencies scanned (Stage 1-2 baseline) · **75** CVEs found (16 CRITICAL / 46 HIGH / 12 MEDIUM / 1 LOW) · **9** dependencies remediated across **8** commits on PR #77.
- **CVE status (branch `fix/depSCAN-20260713-053607`):** 0 unresolved CRITICAL, 0 unresolved HIGH, 1 unresolved MEDIUM (no upstream fix yet).
- **Supply-chain:** typosquat **removed**; untrusted HTTP mirror still declared (unused, non-blocking); audit verdict **BLOCK** — sole blocker is a pre-existing license violation.
- **Licenses:** 1 violation — `com.mysql:mysql-connector-j:8.2.0` is GPL-2.0-with-FOSS-exception (unresolved by the CVE fix; tracked in #76).
- **Remediation:** consolidated fix PR #77 open, not yet merged.
- **Latest gate outcome:** **BLOCK** — license-policy decision required (issue #76); all auto-fixable findings are clear.

Health score breakdown (current branch state, pre-merge)

Factor	Deduction
Unresolved CRITICAL CVEs (0 × -15)	0
Unresolved HIGH CVEs (0 × -8)	0
Unresolved MEDIUM CVEs (1 × -2)	-2
Supply-chain BLOCK findings (1 × -10)	-10
Outdated major-version deps (1 × -3, junit-jupiter)	-3
Score	85 / 100 (Grade B)

Baseline for this run (Stage 1 scan of `main @ 61ed8c3`, before any fix): 16 CRITICAL + 46 HIGH CVEs alone floor the score at **0 / 100 (Grade D)**. The remediation on PR #77 recovers the full 85 points; the remaining 15-point gap is the license-policy decision (#76, -10), the one unfixable-by-version-bump Grype Medium (-2), and the junit-jupiter major-version follow-up (#75, -3).

Top risks (ranked, current branch state)

Coordinate	Risk	Band	Top issue	Status
<code>com.mysql:mysql-connector-j:8.2.0</code>	—	BLOCK	GPL-2.0-with-FOSS-exception license violation	needs human policy decision — issue #76
<code>com.fasterxml.jackson.core:jackson-databind:2.18.8</code>	—	MEDIUM	GHSA-5jnj-h7xm-6q6v (no fix available)	logged, non-blocking
<code>org.junit.jupiter:junit-jupiter:5.10.2</code>	—	LOW	outdated, major version behind (6.1.2)	MAJOR_REVIEW — issue #75

Remediation activity (PR #77, `fix/depSCAN-20260713-053607`)

Dependency	Change	CVEs cleared	Status
log4j-core / log4j-api	2.14.1 → 2.25.4	CVE-2021-44228 (Log4Shell) + 7 more, incl. 2025/2026-dated CVEs missed by the initial 2.17.1 suggestion	in PR
jackson-databind	2.9.8 → 2.16.0 → 2.18.8	CVE-2019-14379 + 53 related, incl. 2 High Grype/GHSA findings caught only at the Stage 4 gate	in PR
guava	24.1.1-jre → 32.0.0-jre	CVE-2023-2976, CVE-2020-8908, CVE-2018-10237	in PR
commons-io	2.4 → 2.14.0	CVE-2021-29425	in PR
commons-lang3	3.4 → 3.18.0	CVE-2025-48924	in PR
mysql-connector-java → mysql-connector-j	8.0.30 → 8.2.0 (coordinate migration)	CVE-2023-22102	in PR
protobuf-java (transitive)	3.21.9 → 3.25.5 (dependencyManagement pin)	CVE-2024-7254 + 3 related	in PR
com.fastxml...:jackson-databind	removed (typosquat)	n/a — supply-chain	in PR

PR #77: open, not merged. **Not included, tracked separately:** junit-jupiter major bump (#75), mysql-connector-j license violation (#76).

Supply-chain findings

Type	Coordinate	Detail	Action
Typosquat	com.fastxml.jackson.core:jackson-databind:2.9.8	Impersonates com.fasterxml.jackson.core; not on Maven Central	Removed in PR #77
Untrusted repository (declared, unused)	http://insecure-mirror.example.net/maven2	Plain-HTTP mirror still declared in <repositories> ; no dependency currently resolves through it	Not removed — flagged for follow-up
License violation	com.mysql:mysql-connector-j:8.2.0	GPL-2.0-with-FOSS-exception, denied in this Apache/MIT/BSD/EPL-only project	Blocks gate — issue #76
Grype Medium (informational)	com.fasterxml.jackson.core:jackson-databind:2.18.8	GHSA-5jmj-h7xm-6q6v, no fix version published	Logged, non-blocking

Tests

- Tests: **2/2 passed**, 0 failures, 0 errors (`mvn clean test`).
- `mvn clean verify` fails on the JaCoCo line-coverage gate — pre-existing, documented in `pom.xml` ("ISSUE #6"), predates this branch, and is explicitly out of scope for this dependency gate.

Gate (Stage 4) — verdict on PR #77: BLOCK

Check	Result	Detail
Unit tests	PASS	2/2 passed
OWASP CVE (0 CRITICAL/HIGH)	PASS	0 unresolved CRITICAL, 0 unresolved HIGH
Supply-chain audit	BLOCK	1 blocking finding: license violation (mysql-connector-j GPL-2.0); 2 non-blocking warnings (Grype Medium, declared-but-unused untrusted repo)

Verdict: BLOCK. Every CVE-driven finding is resolved; the sole remaining blocker is a license-policy decision that only a human can make (issue #76). No auto-merge — a human reviewer must either accept the GPL-2.0-with-FOSS-exception license for this dependency or swap to a permissively-licensed JDBC driver, then re-run the gate.

Trend vs. previous run (2026-06-10)

- Health score: **0 / 100 (D)** → **85 / 100 (B)**, $\Delta +85$.
- CVEs resolved this cycle: 75 (16 CRITICAL, 46 HIGH, 12 MEDIUM, 1 LOW) across 9 dependencies.
- Supply-chain: typosquat and both initially-flagged CRITICAL/HIGH CVE classes cleared; only the pre-existing license violation remains, now isolated as the single blocking condition.

State of supply-chain hygiene (stakeholder summary)

This cycle's scan found the project in a critical state — 16 critical and 46 high-severity CVEs across core dependencies (including an actively-exploited Log4Shell instance), plus an active dependency-confusion (typosquat) attempt. The automated remediation pipeline cleared every one of these through nine targeted, individually-reviewable commits on PR #77, verified by two independent scanners (OWASP Dependency-Check and Grype) after every change — including a second remediation pass after the gate caught two additional high-severity findings the first scanner had missed. What remains is not a security gap but a **policy decision**: whether the GPL-2.0-licensed MySQL driver is acceptable for this project, which is correctly left to a human and tracked in issue #76.

Aggregated from `depscan-report.json`, `depscan-risk-report.json`, and `depscan-supplychain-audit.json`. Generated by the Dependency & Supply-Chain Plugin — Stage 5.